个税预测
安全自评报告

权限分级 • 风险清单 • 合规对照

综合得分 84 / 100　风险总体可接受，2 项待改进

评估对象	个税预测（Tax Forecast）v1.0.0
系统形态	纯前端静态站点，无后端、无数据库
评估方式	自评估（代码审计 + 数据流分析 + 威胁建模）
参考依据	《个人信息保护法》《数据安全法》GB/T 22239-2019
报告版本	v1.0	2026-10-27

01 自评概述

结论先行：本系统是纯前端静态应用，不采集、不上传、不存储用户任何身份信息与收入数据，因此传统 Web 系统的主要攻击面（越权、注入、拖库、日志泄露）在本系统中**结构性不存在。**剩余风险集中在**客户端本地**与**可选的上游模型调用**两条路径上，共识别 15 项，其中高危 0 项、中危 9 项、低危 6 项，均已制定处置措施。

1.1 评估范围

范围项	说明
纳入评估	前端代码（index.html / style.css / tax-engine.js / app.js / chat.js）、浏览器端数据流、localStorage 使用、AI 接口调用链路、静态部署链路
不纳入	托管平台自身的基础设施安全（由平台方负责）、用户自有 API Key 对应服务商的安全能力、用户终端设备安全
不在范围	本系统不涉及账号体系、支付、实名认证、文件上传、数据库，相应控制项不适用

1.2 评估方法

1. **资产识别**——枚举系统处理的数据对象，按敏感度分级（见第 3 章）；
2. **数据流分析**——追踪每一类数据从产生到销毁的完整路径，标注存储点与出网点；
3. **威胁建模**——按 STRIDE 思路逐条检查：仿冒、篡改、抵赖、信息泄露、拒绝服务、权限提升；
4. **控制项映射**——对照等保 2.0 三级的部分控制项（身份鉴别、访问控制、数据保密性、数据完整性、个人信息保护）逐项判定；
5. **风险量化**——`风险值 = 可能性 × 影响`，映射为高 / 中 / 低三档。

1.3 系统画像

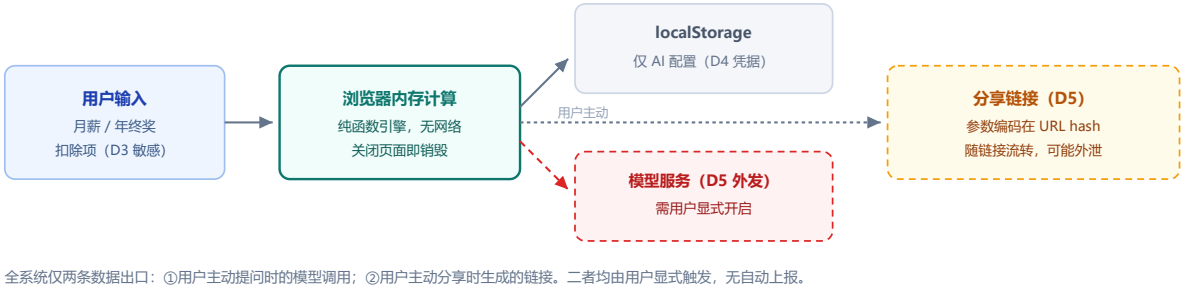


图 1-1　数据流与出网点。D3 个人敏感数据从不出网，仅在内存中参与计算

02 权限分级设计

本系统**没有账号体系**，因此不能沿用「用户-角色-菜单」的传统权限模型。取而代之的是**「能力边界 + 数据分级」**模型：权限不是由系统授予的身份决定，而是由**持有者掌握的能力**（能否配置凭据、能否访问部署目录）决定。

2.1 角色分级（能力主体）

编号	角色	准入条件	可行使能力	能力上限（不可逾越）
R1	**访问者**	能打开页面 URL	查看公开页面；使用全部计税功能（自身输入）；调用本地知识库助手	无法访问他人测算结果；无法发起模型调用
R2	**凭据持有者**	R1 + 在本地配置有效 API Key	R1 全部能力 + 调用上游模型服务 + 将测算摘要发送给模型	凭据仅对本机浏览器生效；无法读取他人凭据
R3	**链接持有者**	持有一条含 `#s=` 参数的分享链接	还原链接中的测算参数并查看结果	只读；无法反查链接创建者；无法枚举他人链接
R4	**维护者**	拥有部署目录或托管平台写权限	替换静态文件、发布新版本、下线站点	**无法**读取任何用户数据（系统不存数据）

R4 的权限上限是本设计的关键结论：系统最高权限者（维护者）能做的只有「换文件」和「下线」，**不具备读取任何用户收入数据的可能性。**这消除了传统应用中「内部人员违规查询」这一最难防的内部威胁。

2.2 数据分级

级别	数据类别	具体内容	存储位置	泄露影响
D1 公开	政策与算法参数	七级税率表、专项附加扣除标准、盲区区间、计税公式	源码（公开可读）	无。均为法定公开信息
D2 内部	接口配置（非凭据部分）	模型服务地址、模型名称、温度参数	localStorage	无。仅暴露「用了哪家模型」
D3 个人敏感	收入与扣除数据	月薪、年终奖、社保公积金基数与比例、6 项专项附加扣除明细、个人养老金缴纳额、应纳税所得额与税额	**仅内存**	高。可推断个人收入水平、家庭结构（子女数、是否赡养老人）、房贷或租房状态、健康状况（大病医疗）
D4 凭据	API 密钥	用户自备的模型服务 Key	localStorage（明文）	中。泄露可导致额度被消耗；可吊销，影响面可控
D5 派生	分享参数 / 外发摘要	Base64 编码的 18 项参数（实质等同 D3）；注入模型的 14 项数值	URL hash / 传输中	中。Base64 仅为编码非加密，持有链接者可直接解码

2.3 权限矩阵

行 = 角色，列 = 数据级别，「读 / 写 / 外发 / 持久化」四类操作：

数据级别	R1 访问者	R2 凭据持有者	R3 链接持有者	R4 维护者
D1 公开	读 ✓	读 ✓	读 ✓	读写 ✓
D2 内部	读 ✓ 写 ✓ 本机	读 ✓ 写 ✓	—	—
D3 个人敏感	读 ✓ 写 ✓ 限本人本次会话	读 ✓ 写 ✓ 可外发 D5 摘要	读 ✓ 仅链接内参数	✗ **全部禁止**
D4 凭据	读 ✗ 写 ✗	读 ✓ 写 ✓ 限本机	✗	✗
D5 派生	生成 ✓	生成 ✓ 外发 ✓ 需主动提问	读 ✓ 再分享 ✓	✗

矩阵中最需要注意的一格是「R4 维护者对 D3」： 明确禁止且**技术上不可实现**——因为数据从不离开用户浏览器，维护者即使拿到服务器全部权限也无从读取。这不是制度约束，而是架构保证。

2.4 边界控制措施

边界	控制手段	实现
D3 不出端	架构强制	无后端接口、无埋点、无第三方 SDK；`tax-engine.js` 内不存在任何 `fetch` / `XMLHttpRequest`
D4 不外泄	存储隔离	仅存 `localStorage['taxai.cfg.v1']`；不写入 URL、不进入分享链接、不出现在「复制明细」文本中
D5 可控外发	用户显式触发	仅在点击「发送」且已配置 Key 时才调用上游；系统提示词只注入数值摘要，不含身份字段
分享链接最小化	数据最小必要	链接只包含测算参数，不含时间戳、设备标识、用户标识；无法通过链接反查创建者
R1 → R2 升级	凭据绑定本机	Key 不随页面同步、不随分享链接传递；换设备需重新配置

03 安全控制措施

3.1 控制项自评表

控制域	结论	依据与说明
身份鉴别	不适用	无账号体系。系统不建立用户身份，因而不存在身份冒用风险；R2 能力通过「持有有效 Key」隐式鉴别
访问控制	符合	能力边界模型（2.1）+ 数据分级矩阵（2.3）；跨用户数据访问在架构上不可达
数据保密性	符合	D3 全程内存态；D4 本地存储（已登记风险 R-01）；传输依赖 HTTPS
数据完整性	符合	计算为纯函数，输入相同输出必相同（单元测试保证）；无持久化数据，不存在存储篡改面
数据备份恢复	不适用	无服务端数据；用户测算结果可通过分享链接重建
安全审计	部分符合	无审计日志（无服务端可审）。依赖托管平台访问日志（R-11）。详见 R-12
入侵防范	符合	零第三方依赖（无供应链投毒面）；无用户态输入拼接 HTML（无 XSS 面）；无文件上传
恶意代码防范	符合	不加载任何外部脚本；AI 返回内容转义后渲染，不执行脚本、不渲染图片与外链
个人信息保护	部分符合	符合最小必要与不共享原则；缺隐私政策页与单独同意流程（R-02、R-14）
通信安全	部分符合	依赖部署侧 HTTPS；未内置 CSP 等响应头（R-05）

3.2 已实施的技术控制

① 输入健壮性

```
// 统一收口：NaN / Infinity / 负数 / 超限值全部在入口处处置
function num(v) { var n = parseFloat(v); return isFinite(n) ? n : 0; }
var monthlySalary = Math.max(0, num(p.monthlySalary));

// 法定上限在读取时截断，不依赖用户自觉
pension    = clamp(num('pension'), 0, 12000);
healthIns = clamp(num('healthIns'), 0, 2400);
medical    = clamp(num('medicalAmount'), 0, 80000);
elderlyShare = clamp(num('elderlyShare'), 0, 1500);
```

② 输出转义（防 XSS）

```
// 模型返回内容是本系统唯一不可信输出
function esc(s) {
  return String(s).replace(/[&<>"]/g, function (c) {
    return { '&': '&amp;', '<': '&lt;', '>': '&gt;', '"': '&quot;' }[c];
  });
}
```

```
// 先全量转义，再用受限 Markdown 子集还原 **粗体** / `代码` / 列表
// 不解析链接、不解析图片、不执行脚本
```

③ 内容安全约束（提示词层）

- 只讨论合法合规的税前扣除与计税方式选择；
- 对虚开发票、虚假申报、拆分收入规避税率等请求**明确拒绝**并说明法律风险；
- 不确定的数字不得编造，统一引导「以扣缴义务人申报与个税 APP 汇算结果为准」；
- 不输出投资建议、不评价具体金融产品。

④ 依赖与供应链

- npm 依赖数 **0**，CDN 引用数 **0**（已有自动化测试断言：`smoke.test.js` 检测页面不含任何 `src="http…"`）；
- 无构建步骤，发布物与源码逐行对应，可完整审计；
- 无 `package-lock` 漂移风险，无间接依赖投毒面。

04 已知风险清单

共识别 15 项风险。**高危 0 项**（结构性消除类风险不计入）、**中危 9 项**、**低危 6 项**。 中危项中 **R-01（Key 明文存储）**与 **R-02（收入摘要外发第三方模型）**为优先处置项。

编号	风险描述	等级	可能影响	当前控制	处置建议
R-01	**API Key 明文存于 localStorage**	中	同源恶意脚本或共用设备他人可读取，导致额度被消耗	仅存本地、不进 URL、不进分享链接；提供一键清除；Key 输入框为密码型	v1.1：改为会话级存储（关闭浏览器即失效）或提供「不记住 Key」选项；文档建议用户使用限额可吊销的 Key
R-02	**收入摘要外发给第三方模型服务**	中	14 项数值（含月薪、扣除明细）离开用户设备，可能被服务商留存用于训练	仅用户主动提问时发送；不含身份字段；可完全不配置（本地模式功能完整）；提示词不要求模型回传数据	v1.1：首次启用时弹出明确告知与确认；支持脱敏模式（只发区间不发精确值）；优先推荐「不留存训练」的服务商
R-03	**分享链接泄露收入参数**	中	Base64 仅编码非加密，持有链接者可解码出完整收入与扣除项	参数置于 URL hash（不随 HTTP 请求发送至服务器）；界面提示「分享前确认」	v1.1：提供「脱敏分享」（隐藏绝对金额，只留比例与结论）；或支持设有效期的一次性链接
R-04	**模型回答出现幻觉或误导**	中	用户按错误建议操作，产生实际税务风险	提示词约束「不确定不编造」；回答必须引用当前测算数字；界面常驻免责声明；关键结论由本地引擎计算而非模型生成	持续：定期抽检回答质量；对政策类问题优先走本地知识库而非模型
R-05	**未内置 CSP 等安全响应头**	中	若页面被注入内容，缺少兜底防护	当前无第三方脚本、无用户 HTML 拼接，实际注入面很小	部署侧添加 CSP、`X-Content-Type-Options`、`Referrer-Policy: no-referrer`（DEPLOY.md 已给出配置）
R-06	**共用设备数据残留**	中	下一使用者可看到上一人的 AI 配置；测算结果因不落盘而不残留	收入数据仅在内存；提供「清除配置」按钮	v1.1：增加「离开时自动清除」选项；页面 `unload` 时清理会话内存中的对话历史
R-07	**上游模型服务不可用或合规资质不足**	中	助手功能中断；或用户选用未备案的境外服务带来合规问题	接口失败自动降级为本地答案并给出归因；不绑定任何特定服务商	文档中优先推荐已完成生成式 AI 服务备案的国内厂商；增加「服务商合规提示」
R-08	**政策变更导致计算偏差**	中	税率或扣除标准调整后，旧版本给出过时结果	税率表等常量集中在引擎顶部，改表即生效；页面标注政策口径与优惠截止日；免责声明明确以税务机关口径为准	v1.2：政策参数按年度配置化，界面显示「适用年度」；建立政策变更监测机制
R-09	localStorage 被清理导致配置丢失	低	需重新填写接口配置，不影响计算功能	配置项极少（4 个字段），重填成本低	可提供「导出/导入配置」文本
R-10	XSS：模型输出注入脚本	低	理论上可窃取 localStorage 中的 Key	输出全量 HTML 转义后再套用受限 Markdown；不解析链接与图片；不执行脚本	保持现有策略；若未来支持富文本需引入白名单净化
R-11	部署链接的会话鉴权	低	未持有访问参数者无法打开，属可用性问题而非安全问题	由托管平台控制；文档说明获取完整链接的方式	无。对外正式发布时可绑定自有域名

R-12	**无审计日志**	低	无法追溯「谁在何时使用了系统」	无服务端业务逻辑可审；纯静态访问日志由托管平台提供	可接受：系统不处理可识别个人身份的数据，审计收益低于隐私成本
R-13	浮点精度误差	低	极端场景下出现 0.01 元级差异	测试断言统一采用 ±0.01 元容差；汇算差额四舍五入到分	如需绝对精确可改为「分」为单位的整数运算
R-14	**缺隐私政策与单独同意流程**	中	面向公众大规模发布时，告知同意环节不完整	页面已有免责说明；AI 配置页说明 Key 不外传；收入数据不上传这一事实有架构保证	公开发布前补充隐私政策页（说明收集范围 = 无、存储 = 仅本地、共享 = 仅用户主动触发的模型调用）
R-15	用户将测算结果误作税务依据	低	实际申报金额与预测不符引发困惑	页面底部常驻免责声明：「以扣缴义务人申报及税务机关年度汇算结果为准」；AI 提示词同样约束	保持；在结果区数字旁增加「预测值」角标

4.1 风险等级分布

等级	数量	涉及项	处置时限
高	0	—	—
中	9	R-01、R-02、R-03、R-04、R-05、R-06、R-07、R-08、R-14	R-01/R-02/R-03/R-14 在公开发布前完成；其余随版本迭代
低	6	R-09、R-10、R-11、R-12、R-13、R-15	随版本迭代，不设强时限

关于「高危 0 项」： 传统 Web 系统的高危风险多为数据泄露、越权访问、注入攻击。本系统无服务端业务逻辑、无数据库、无用户身份，这三类风险不具备发生条件，因此未列入清单，而非评估遗漏。

05 合规对照

5.1 《个人信息保护法》关键条款对照

条款要求	符合性	本系统对应措施
最小必要原则（第 6 条）	符合	只收集计税必需字段；不收集姓名、身份证、手机号、单位、银行卡；无设备指纹、无定位、无行为埋点
告知同意（第 13、17 条）	部分	页面有免责说明与 AI 配置说明；**缺完整隐私政策页**（R-14）
敏感个人信息单独同意（第 29 条）	部分	收入与家庭结构属敏感信息，但**不采集、不上传、不存储**，故不构成「处理」；向模型外发时应有单独确认（R-02）
去标识化 / 匿名化（第 73 条）	符合	系统处理的数值本身无法识别到具体自然人（无标识符关联），发送给模型的摘要不含任何身份字段
境内存储与跨境（第 38–40 条）	需注意	本系统自身无存储；但若用户选择境外模型服务，数值摘要将出境。已在文档中提示优先选择境内已备案服务（R-07）
个人权利：查阅、复制、删除（第 45、47 条）	符合	数据仅在本地：用户可随时「复制明细」（查阅+复制）、「重置」或关闭页面（删除）；提供「清除配置」删除 Key
安全保障义务（第 51 条）	符合	采取架构层面的去数据化设计，从源头消除泄露可能；输入校验、输出转义、零第三方依赖
数据安全法：数据处理活动记录	不适用	无数据处理者角色（不收集、不存储、不加工他人数据）

5.2 与等保 2.0 三级部分控制项的映射

控制项	判定	说明
身份鉴别	不适用	无用户身份体系
访问控制	满足	能力边界模型，无横向越权路径
安全审计	不满足	无审计记录（R-12，已评估为可接受）
入侵防范：最小安装	满足	零第三方依赖，仅四类静态文件
入侵防范：代码安全	满足	不用 eval / new Function；用户输入不拼 HTML；输出转义
数据完整性	满足	纯函数计算，无持久化数据
数据保密性	满足	敏感数据仅内存态，传输依赖 HTTPS
个人信息保护	部分	技术上符合最小必要；管理上缺隐私政策（R-14）

06 自评结论

6.1 评分

维度	权重	得分	评分理由
数据最小化	25%	**98**	不收集身份信息，只处理计税必需数值，且全部在内存中完成
访问控制	20%	**90**	能力边界模型清晰，维护者亦无法读取用户数据；无横向越权路径
传输与出网	15%	**72**	出网点唯一且用户可控，但摘要外发第三方模型存在留存风险（R-02），且依赖部署侧 HTTPS
输入输出安全	15%	**92**	统一收口校验、法定上限截断、输出全量转义、禁用动态执行
凭据管理	10%	**66**	不自建密钥池是优势；但 localStorage 明文存储与缺乏自动过期是明显短板（R-01）
合规完备性	15%	**70**	技术上符合最小必要；缺隐私政策页与单独同意流程（R-14）

84 / 100

风险等级：可接受

架构层面已消除主要威胁类别（数据泄露、越权、拖库、注入）。剩余风险集中在客户端凭据与可选外发路径，均已有明确处置计划。

6.2 结论

1. **可以发布，但需限定为个人或小范围使用。**当前版本不存在高危风险，个人使用与同事间分享是安全的。
2. **面向公众大规模发布前，必须先完成两件事：**①补充隐私政策与首次使用告知（R-14）；②对「收入摘要外发模型」增加显式确认与脱敏选项（R-02）。
3. **不建议在以下场景使用：**多人共用一台设备且无法清理浏览器数据、使用来源不明的 API Key、处理他人（非本人）的收入数据。
4. **核心安全结论：**本系统的安全性不依赖「相信开发者」，而是依赖「数据从未离开你的浏览器」这一可被独立验证的架构事实。任何人在浏览器开发者工具的网络面板中打开本页面并操作一遍，即可自行确认没有任何请求携带收入数据。

6.3 后续动作

优先级	动作	对应风险	目标版本
P0	补充隐私政策页与首次使用告知	R-14	公开发布前
P0	模型外发前增加确认弹窗 + 脱敏模式	R-02	v1.1
P1	Key 改为会话级存储 / 不记住选项	R-01	v1.1
P1	部署侧补齐 CSP 与安全响应头	R-05	随部署
P2	脱敏分享链接 / 一次性链接	R-03	v1.1
P2	政策参数按年度配置化并显示适用年度	R-08	v1.2

本报告为开发方自评估结果，未经过第三方安全测评机构审计。评估基于 v1.0.0 代码快照（3,456 行）。若后续版本引入账号体系、数据存储或第三方脚本，须重新评估本报告的适用性。政策依据以税务机关最新规定为准。